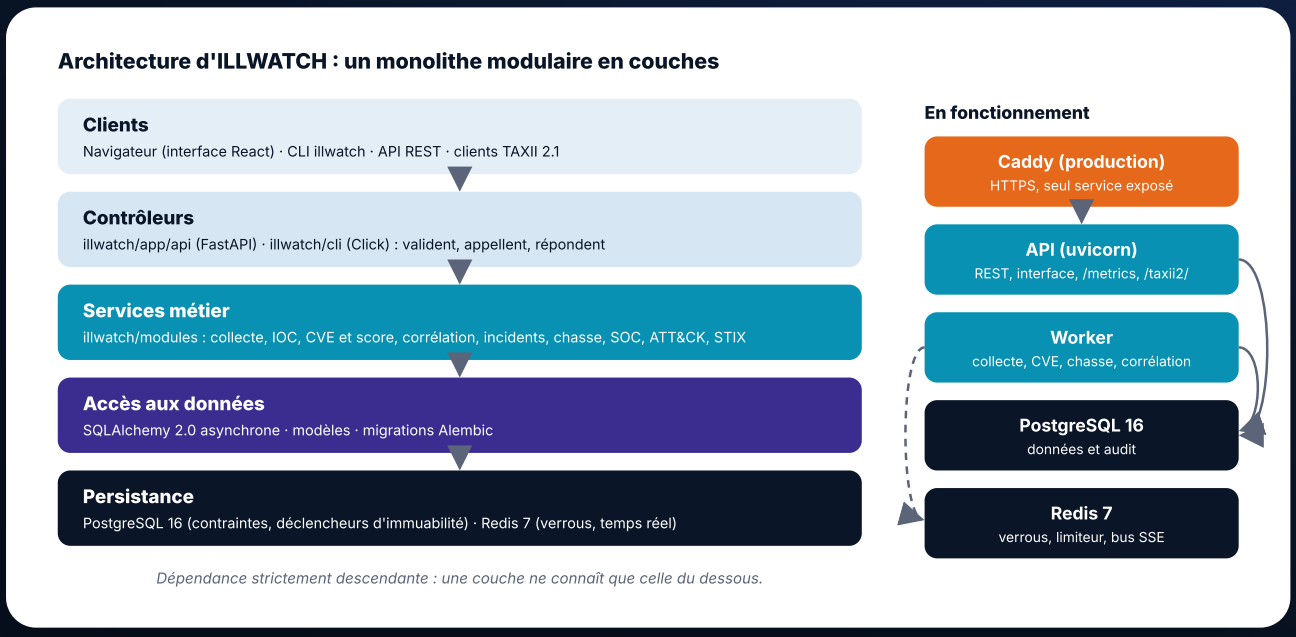
ILL Watch

CAHIER DES CHARGES · VERSION 2.0

Exigences et critères d'acceptation

La spécification opposable d'ILLWATCH : besoins, exigences fonctionnelles RF-01 à RF-57 avec leur statut réel, exigences non fonctionnelles mesurées, architecture, modèle de données, interfaces et risques.



Dépendance strictement descendante : une couche ne connaît que celle du dessous.

VERSION
2.0 · 30 octobre 2026

LOGICIEL
ILLWATCH 0.2.0.dev0

AUTEUR
Godwill FOKA · CyberillSec, une initiative CYBERILL

POUR QUI
Équipe projet, contributeurs, partenaires

Sommaire

1	Historique des versions	1
2	1. Contexte et mission	1
3	2. Besoins et acteurs	2
4	3. Exigences fonctionnelles	3
5	4. Exigences non fonctionnelles	6
6	5. Architecture et choix techniques	7
7	6. Modèle de données	8
8	7. Interfaces	9
9	8. Critères d'acceptation	10
10	9. Risques	10
11	10. Glossaire	11

Version en ligne, toujours à jour : https://godwillfoka.github.io/cyberillsec-illwatch/
Les numéros de page renvoient au pied de page du document.

Projet	ILLWATCH : plateforme de surveillance de sécurité et de renseignement sur les menaces
Initiative	CyberillSec, une initiative CYBERILL
Auteur et architecte	Godwill FOKA, Lead Architect et Security Engineer, Berlin
Version	**v2.0 du 30/10/2026** (remplace la v1.0.0 « Master Engineering Baseline » de juillet 2026)
Dépôt	`gitlab.com/GodwillFoka/cyberillsec-illwatch` (référence), GitHub (miroir)
Statut	Approuvé pour développement ; fait foi pour l'implémentation

> **Hiérarchie des sources.** En cas de contradiction : un ADR accepté (`docs/adr/`) tranche, puis ce cahier des charges, puis la vision produit. Un écart non tranché fait l'objet d'un ADR, jamais d'une décision silencieuse dans le code. La v1.0.0 d'origine est conservée en PDF (`docs/pdf/`) pour l'historique.

Historique des versions

Version	Date	Changements
v1.0.0	07/2026	Baseline : six modules, exigences RF-01 à RF-28, 44 tâches sur 9 semaines
v1.x	09/2026 à 10/2026	Écarts tranchés par ADR-001 à ADR-028 (score, hébergement, renommage, interface web…)
v2.0	**30/10/2026**	Refonte : nom ILLWATCH (anciennement SENTRY), statut de chaque exigence, exigences M7 à M11 (RF-29 à RF-52), exigences non fonctionnelles mesurées, modèle de données et API à jour

1. Contexte et mission

1.1 CYBERILL et CyberillSec

CYBERILL est une initiative d'ingénierie et de résilience numérique fondée à Berlin par Godwill FOKA, organisée en six branches : CyberillSec (renseignement sur les menaces), Cyberill Labs (recherche), Cyberill Academy (formation), Cyberill Consulting (conseil), Cyberill CERT (réponse à incident) et Cyberill Cloud (plateformes hébergées). **ILLWATCH** est le moteur logiciel de CyberillSec. Il s'appelait SENTRY jusqu'au 08/10/2026 (nom déjà pris) ; seules les références historiques gardent l'ancien nom.

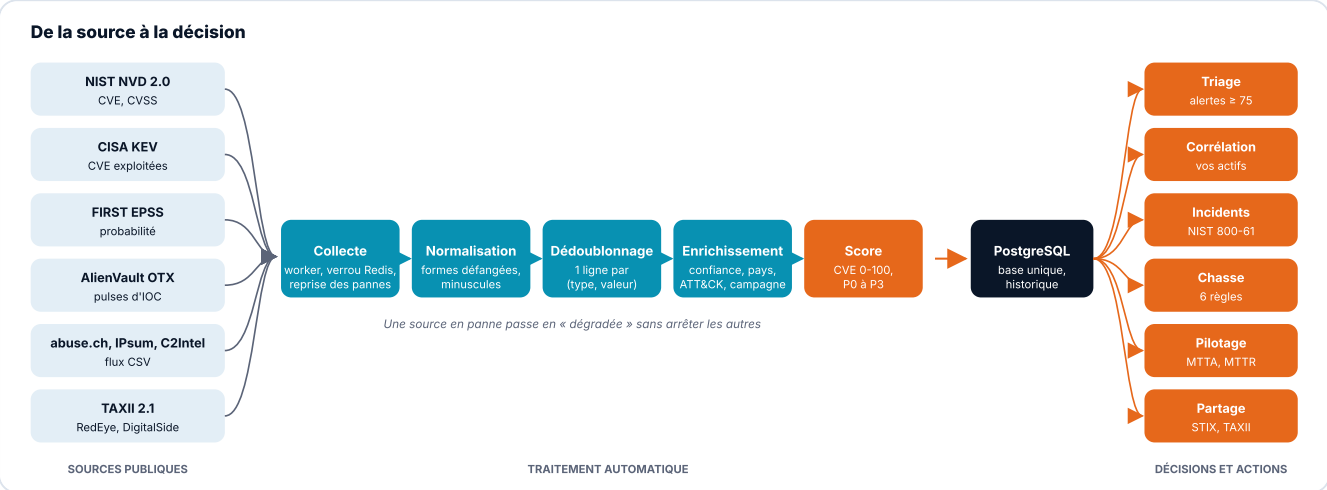
1.2 Le problème

1. **Exploitation accélérée** : les attaquants exploitent une vulnérabilité publiée en moins de 48 heures ; la correction mensuelle ne suffit plus.

2. **Obligations européennes** : NIS 2 et DORA imposent une veille active et la notification des incidents majeurs sous 24 à 72 heures.
3. **Coût** : les plateformes commerciales de renseignement coûtent de 40 000 à 150 000 € par an, hors de portée des PME, des ETI et des collectivités.
4. **Lourdeur** : les plateformes open source complètes exigent un cluster et 16 Go de mémoire au minimum.
5. **Bruit** : un analyste passe 60 à 70 % de son temps à recopier des indicateurs et à trier des alertes en double.

1.3 La mission

Donner à une équipe de 1 à 10 personnes ce dont elle a besoin le lundi matin : **quoi corriger d'abord, quoi bloquer, ce qui a changé, et la preuve de ce qui a été fait**, avec une plateforme open source (licence MIT), hébergeable en Europe, qui tient dans moins de 256 Mo de mémoire.



2. Besoins et acteurs

2.1 Besoins utilisateurs

Réf.	Profil	Besoin	Réponse d'ILLWATCH
BU-01	Analyste SOC (L1, L2)	une source unique où chaque alerte arrive enrichie et priorisée	triage, score décomposé, corrélation
BU-02	Analyste CTI, chasseur de menaces	filtrer des centaines de milliers d'IOC, chasser, exporter	indicateurs, chasse, exports CSV, JSON, STIX, TAXII
BU-03	RSSI	des métriques de pilotage et la preuve des actions	pilotage (MTTA, MTTR, délais cibles), audit immuable
BU-04	Administrateur système, DevOps	une installation légère, pilotable par API et CLI	Docker Compose, CLI complète, API REST, sondes

Réf.	Profil	Besoin	Réponse d'ILLWATCH
BU-05	Responsable du parc	déclarer l'inventaire sans double saisie	import Excel ou CSV, export réimportable
BU-06	Partenaire (SIEM, CERT)	recevoir le renseignement sans accès à l'interface	serveur TAXII 2.1 en lecture seule

2.2 Acteurs

Acteur	Rôle	Droits
Administrateur	ADMIN	tout, dont comptes, sources, paramètres, suppressions, audit
Analyste	ANALYST	triage, incidents, chasse, inventaire, faux positifs, campagnes
Lecteur	VIEWER	consultation ; partenaire TAXII
Worker	automate	collecte, CVE, corrélation, chasse, entretien
Sources externes		NVD, KEV, EPSS, OTX, abuse.ch, IPsum, C2IntelFeeds, TAXII, ATT&CK, DB-IP
Visiteur du site	public	demande de démonstration

La matrice détaillée des actions par rôle est dans le Manuel fonctionnel.

3. Exigences fonctionnelles

Statuts : ✅ **constatée** sur données réelles ; 🟢 **livrée** (code, tests et CI verts), à constater sur le poste ou le serveur ; 🟡 **partielle** ; ⏳ **prévue**. **Priorités** : P0 indispensable, P1 importante, P2 souhaitable.

3.1 Modules de la v1.0 (M1 à M6)

Réf.	Module	Exigence	Prio.	Statut
RF-01	MOD-01	Charger la configuration, typée et validée au démarrage, depuis l'environnement ou un `.env`	P0	✅
RF-02	MOD-01	Initialiser et faire évoluer le schéma par migrations automatisées	P0	✅
RF-03	MOD-01	Fournir une CLI d'initialisation, de peuplement (seed) et de diagnostic	P1	✅
RF-04	MOD-02	Gérer les sources de flux (création, lecture, modification, suppression)	P0	✅
RF-05	MOD-02	Collecter les flux de façon asynchrone, sans bloquer l'API	P0	✅
RF-06	MOD-02	Lire les formats JSON, CSV, STIX 2.1 et TAXII 2.1	P0	✅
RF-07	MOD-02	Extraire et stocker les IOC : IPv4, IPv6, plages CIDR, domaines, URL, e-mails, empreintes MD5, SHA-1, SHA-256	P0	✅

Réf.	Module	Exigence	Prio.	Statut
RF-08	MOD-02	Dédoublonner : une valeur revue met à jour l'IOC existant, sans nouvelle ligne	P0	✅
RF-09	MOD-02	Exécuter un worker périodique qui collecte les sources échues	P1	✅
RF-10	MOD-02	Intégrer le connecteur AlienVault OTX	P1	✅
RF-11	MOD-03	Synchroniser les CVE avec l'API NVD 2.0 (pagination, débit limité)	P0	✅
RF-12	MOD-03	Importer le catalogue CISA KEV	P0	✅
RF-13	MOD-03	Importer les scores EPSS de FIRST	P0	✅
RF-14	MOD-03	Calculer un score de risque composite déterministe entre 0 et 100 (ADR-001, ADR-014)	P0	✅
RF-15	MOD-03	Rechercher et filtrer les CVE sur plusieurs critères	P1	✅
RF-16	MOD-03	Émettre une alerte quand une CVE franchit le seuil de risque	P1	✅
RF-17	MOD-04	Modéliser les incidents avec une sévérité	P0	✅
RF-18	MOD-04	Appliquer une machine d'état stricte à 6 étapes (NIST SP 800-61)	P0	✅
RF-19	MOD-04	Tenir une chronologie immuable par incident	P0	✅
RF-20	MOD-04	Associer des IOC et des CVE à un incident	P1	✅
RF-21	MOD-05	Exposer la synthèse des indicateurs clés en temps réel	P0	✅
RF-22	MOD-05	Restituer l'activité récente (menaces et vulnérabilités)	P1	✅
RF-23	MOD-05	Afficher une vue console de l'état du SOC	P1	✅
RF-24	MOD-05	Exporter les données en JSON et CSV	P1	✅
RF-25	MOD-06	Évaluer des règles de chasse par comparaison de motifs	P1	✅
RF-26	MOD-06	Embarquer un catalogue de règles opérationnelles (6 règles livrées pour 5 demandées)	P1	✅
RF-27	MOD-06	Lancer une chasse manuelle, planifiée ou depuis un incident	P1	✅
RF-28	MOD-06	Enregistrer les sessions de chasse et leurs correspondances	P1	✅

3.2 Durcissement et interface (M7)

Réf.	Exigence	Prio.	Statut
RF-29	Journal d'audit en ajout seul : connexions, refus d'accès, administration, exports, chasses	P0	🟢
RF-30	Rôles PostgreSQL séparés : migrations par le propriétaire, application sans droit de structure	P0	🟢

Réf.	Exigence	Prio.	Statut
RF-31	Sessions révocables : jeton d'accès de 15 minutes, jeton de rafraîchissement rotatif, rejeu détecté	P0	🟢
RF-32	Limitation des tentatives de connexion par couple compte et adresse, par compte, par adresse	P0	🟢
RF-33	Sondes de vivacité (`/health`) et de disponibilité (`/ready`)	P1	🟢
RF-34	Sauvegarde vérifiée et restauration testée	P0	🟢
RF-35	Déploiement HTTPS par reverse proxy, migrations dans un conteneur éphémère	P0	🟡 constaté en local, serveur européen à louer
RF-36	Interface web temps réel (ADR-016) : vue d'ensemble, triage, incidents, indicateurs, CVE, chasse, sources, corrélations, inventaire, campagnes, pilotage, administration	P0	🟢
RF-37	Interface et textes du serveur en cinq langues (français, anglais, allemand, espagnol, chinois), langue choisie selon le pays (ADR-027)	P1	🟢

3.3 Détection et corrélation (M8)

Réf.	Exigence	Prio.	Statut
RF-38	Score de confiance de chaque IOC (sources pondérées par leur fiabilité, fraîcheur, récurrence) (ADR-017)	P0	✅
RF-39	Enrichissement hors ligne des adresses IP : pays, système autonome (ADR-019)	P1	✅
RF-40	Inventaire d'actifs : produit, éditeur, version, plateforme, criticité, adresses, domaines (ADR-020)	P0	✅
RF-41	**Import et export de l'inventaire en Excel ou CSV, avec aperçu et import tout ou rien (ADR-028)**	P0	🟢
RF-42	Corrélation inventaire × CVE × IOC (CORR-01 à CORR-03), score justifié, comparaison des versions (ADR-020, ADR-021)	P0	✅
RF-43	Plancher KEV : une CVE exploitée n'est jamais sous P1 ; EPSS manquant remplacé par la dernière valeur (ADR-014)	P0	✅

3.4 Opérations SOC (M9)

Réf.	Exigence	Prio.	Statut
RF-44	Niveaux SOC L1, L2, L3 et escalade motivée, consignée dans la chronologie (ADR-022)	P0	🟢
RF-45	Faux positifs : liste d'exclusion des IOC ; évènement corrélé écarté jamais rouvert	P0	🟢
RF-46	Chasse depuis l'incident ; recommandations de réponse par phase NIST	P1	🟢
RF-47	Pilotage : MTTA, MTTR, délais cibles par sévérité, dépassements, charge par analyste	P1	🟢

3.5 Renseignement contextuel (M10)

Réf.	Exigence	Prio.	Statut
RF-48	Référentiel MITRE ATT&CK : technique de chaque détection, acteur cité (ADR-023)	P1	🟢
RF-49	Campagnes : infrastructure rattachée, acteur, attribution par l'infrastructure (ADR-024)	P1	🟢
RF-50	Partage : export STIX 2.1 et serveur TAXII 2.1 en lecture seule (ADR-025)	P1	🟢

3.6 Observabilité et déploiement (M11)

Réf.	Exigence	Prio.	Statut
RF-51	Métriques Prometheus (`/metrics`), tableaux Grafana, 10 alertes (ADR-026)	P1	🟢
RF-52	Environnements développement, préproduction, production ; acceptation en CI sur jeu figé ; 7 jours de préproduction sans intervention	P0	🟡 serveur à louer

3.7 Exigences prévues après la v0.2.0

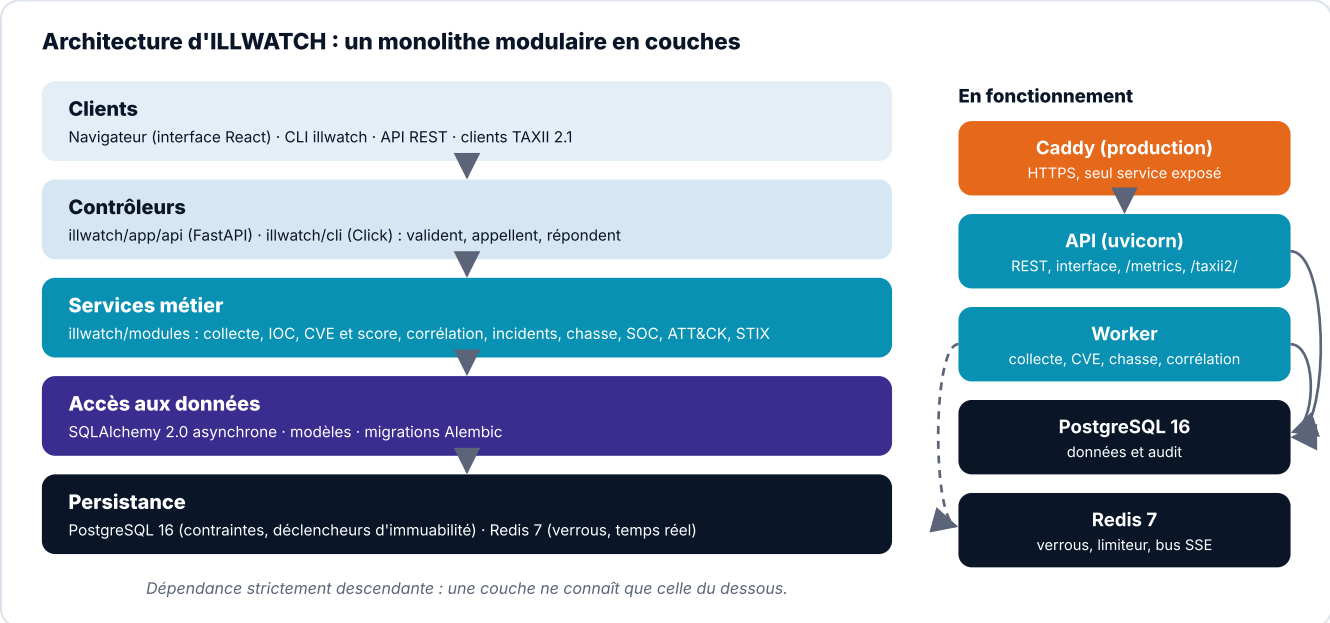
Réf.	Exigence	Prio.
RF-53	Assistant d'analyse (modèle de langage et recherche augmentée) sur bulletins et incidents	P2
RF-54	Multi-organisation (multi-tenant) et authentification unique (OIDC)	P1
RF-55	Connecteurs de gestion de parc (GLPI, CMDB) pour l'inventaire	P2
RF-56	Import de règles Sigma depuis les collections TAXII	P2
RF-57	Facteur CWE dans le score, avec rééquilibrage des poids (ADR à rédiger)	P2

4. Exigences non fonctionnelles

Réf.	Catégorie	Exigence	Mesure constatée
RNF-SEC-01	Sécurité	TLS en production, aucun secret dans le code ni en base	Caddy TLS 1.3 constaté en local ; gitleaks 0 vrai secret ; clés en gabarits
RNF-SEC-02	Sécurité	Entrées validées et typées, aucune requête SQL concaténée	Pydantic `extra="forbid"` ; SAST Semgrep 0 constat ; bandit vert
RNF-SEC-03	Sécurité	Protection SSRF des collectes	liste blanche d'adresses publiques, DNS vérifié, redirections revalidées
RNF-SEC-04	Sécurité	Image sans vulnérabilité critique	0 Critical (Container Scanning, 07/10/2026)

Réf.	Catégorie	Exigence	Mesure constatée
RNF-SEC-05	Sécurité	Fichiers importés bornés (taille, lignes, archive)	inventaire : 2 Mo, 5 000 lignes, 40 Mo décompressés
RNF-PERF-01	Performance	P95 des listes de CVE inférieur à 250 ms	8 ms (filtres), 108 ms (recherche) sur 30 000 CVE
RNF-PERF-02	Performance	1 000 IOC ingérés en moins de 5 s	vérifié par test à chaque pipeline
RNF-PERF-03	Performance	Tableau de bord en moins de 1 s, export de 500 000 IOC en moins de 15 s	0,63 s et 12,0 s (528 453 IOC, 08/10/2026)
RNF-MEM-01	Ressources	Application en moins de 256 Mo	pic de 120 Mo à l'ingestion de 37 000 IOC
RNF-DISP-01	Disponibilité	99,5 % hors maintenance	à mesurer pendant les 7 jours de préproduction
RNF-MAIN-01	Maintenabilité	ruff et mypy strict sans erreur, couverture d'au moins 80 %	environ 94 % ; plus de 670 tests
RNF-MAIN-02	Maintenabilité	Chaque décision structurante tracée par un ADR	28 ADR
RNF-ACC-01	Accessibilité	Site de présentation conforme WCAG 2.2 AA	axe-core en CI
RNF-EDIT-01	Rédaction	Ni tiret long ni tiret moyen dans le dépôt	test `test_ponctuation.py`

5. Architecture et choix techniques

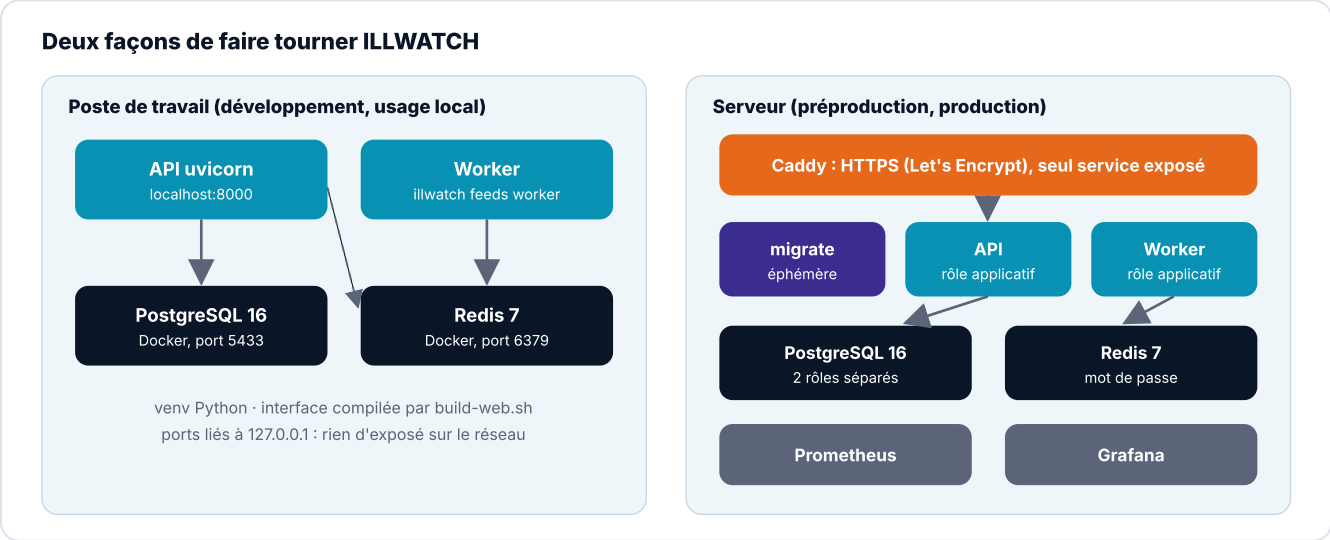


Monolithe modulaire en couches : la dépendance est strictement descendante ; les contrôleurs (API, CLI) ne contiennent aucune logique métier ; le score et la machine d'état des incidents sont des fonctions

pures, testées à 100 %. Le détail est dans Architecture.

Couche	Choix	Raison
Langage	Python 3.12 et 3.14	langue de l'écosystème CTI (STIX, TAXII, YARA, Sigma)
API	FastAPI, Pydantic v2	validation stricte, OpenAPI automatique
Données	SQLAlchemy 2.0 asynchrone, asyncpg, PostgreSQL 16, Alembic	contraintes et déclencheurs portés par la base
Cache et temps réel	Redis 7	verrous du worker, limiteur, bus d'évènements
Interface	React 19, TypeScript, Vite	types générés depuis l'OpenAPI
Fichiers bureautiques	openpyxl	lecture et écriture Excel en Python pur (ADR-028)
Déploiement	Docker Compose, Caddy	HTTPS automatique, un seul service exposé
Observabilité	Prometheus, Grafana	métriques sans dépendance côté application

Délibérément écartés : microservices (le monolithe tient 100 000 évènements par jour), Elasticsearch (PostgreSQL indexé suffit), moteur Sigma complet (six règles déterministes suffisent sur des observables).



6. Modèle de données

28 tables, créées par 21 migrations Alembic vérifiées à chaque pipeline (montée, contrôle, descente, remontée). Les contraintes métier sont portées par la base : clés étrangères, unicité, contrôles sur chaque énumération, déclencheurs d'immuabilité.

Domaine	Tables
Comptes et sécurité	`users`, `refresh_tokens`, `audit_events` (ajout seul)
Renseignement	`threat_feeds`, `collection_runs`, `collector_state`, `indicators`, `indicator_sources`, `exclusions`
Enrichissement	`enrichment_datasets`, `ip_ranges`
Vulnérabilités	`cves`, `cve_priority_history`, `cve_alerts`
Incidents	`incidents`, `incident_events` (ajout seul), `incident_indicators`, `incident_cves`
Chasse	`hunting_sessions`, `hunting_matches`
Corrélation	`assets`, `correlated_events`
Contexte adverse	`attack_techniques`, `attack_actors`, `attack_uses`, `campaigns`, `campaign_indicators`
Site	`demo_requests`

Index critiques : unicité `(type, valeur)` des IOC, dernière observation (expiration), score et priorité des CVE, chronologie des incidents.

7. Interfaces

Interface	Contenu
Application web	12 écrans, temps réel, 5 langues
API REST `/api/v1`	77 routes ; documentation interactive `/docs` hors production
CLI `illwatch`	71 commandes : `db`, `users`, `feeds`, `cves`, `assets`, `correlate`, `incidents`, `hunt`, `soc`, `campaigns`, `attack`, `enrich`, `stix`, `taxii`, `audit`, `dashboard`, `status`…
TAXII 2.1 `/taxii2/`	collections « indicateurs » et « campagnes », lecture seule
Métriques `/metrics`	format Prometheus, protégé par jeton ou réseau interne
Webhook	une notification par alerte CVE
Fichiers	inventaire Excel ou CSV ; exports CSV, JSON, STIX 2.1 ; sauvegardes PostgreSQL

8. Critères d'acceptation

Critère	Mesure	État
Scénario SOC de bout en bout	48 contrôles (`scripts/scenario_soc.py`), sur données réelles et en CI	✅ 48/48
Jalons M1 à M6	`illwatch status` sur données réelles	✅
Corrélation sur jeu figé	100 % des cas attendus détectés, taux de faux positifs publié	✅ 100 % / 0 %
Parcours L1 → L2 → L3 sans quitter ILLWATCH, MTTR mesuré	scénario d'acceptation	🟢 constaté en CI
Technique ATT&CK et acteur affichés sur une alerte	scénario d'acceptation	🟢 constaté en CI
Déploiement HTTPS sur serveur européen, note SSL Labs A	workflow « Clôture M7 »	⏳
7 jours de préproduction sans intervention, restauration testée	workflow et journal du serveur	⏳
Import d'un inventaire de 1 000 lignes depuis Excel, sans erreur ni perte	tests `test_inventory_file.py` et capture CI	🟢

9. Risques

Réf.	Risque	Gravité	Mesure
RSK-01	Limites de débit des API (NVD)	élevée	clés gratuites, backoff, reprise
RSK-02	Source externe indisponible	moyenne	collecteurs isolés, retrait progressif
RSK-03	Volumétrie des IOC	élevée	expiration par type, index, pagination par clé
RSK-04	Dérive du périmètre	moyenne	jalons à critères de sortie constatés ; idées au backlog
RSK-05	Régression	moyenne	deux pipelines CI, validation réelle hebdomadaire
RSK-06	Panne d'EPSS	moyenne	plancher KEV et dernière valeur connue (ADR-014)
RSK-07	Inventaire mal nommé	moyenne	aide à la saisie, comparaison des versions, mesure sur jeu figé
RSK-08	Fichier importé hostile	moyenne	plafonds, archive contrôlée, refus listés
RSK-09	Porteur unique	élevée	documentation, ADR, tests ; ouverture aux contributeurs

10. Glossaire

Voir le Manuel fonctionnel, section 14.